

Inicio de sesión con correo y contraseña

¿Qué es esto?

Una pantalla de inicio de sesión donde ingresas tu correo y tu contraseña para entrar a la aplicación. Si te equivocas varias veces seguidas, la cuenta se bloquea por unos minutos para proteger tus datos.

¿Por qué se hace?

Hasta ahora cualquier persona con el enlace podía llegar a las pantallas internas. Con el inicio de sesión, solo quienes tienen una cuenta válida acceden, y cada acción queda asociada a una persona.

¿Qué podrás hacer?

- Entrar a la aplicación con tu correo y contraseña.
- Marcar "Recordarme" para no tener que iniciar sesión en cada visita desde tu equipo.
- Saber con un mensaje claro cuándo el correo o la contraseña no son correctos.

¿Cómo lo vas a usar?

1. Abre la aplicación: verás la pantalla de inicio de sesión.
2. Escribe tu correo y tu contraseña.
3. Si quieres, marca "Recordarme".
4. Haz clic en "Iniciar sesión" y entras a tu panel.
5. Si la combinación es incorrecta, aparece un aviso para que vuelvas a intentarlo.

¿Qué cambia respecto a hoy?

Antes se entraba directo a las pantallas internas. Ahora el primer paso siempre es iniciar sesión. Una vez dentro, todo funciona igual que siempre.

Cosas a tener en cuenta

- Tras 5 intentos fallidos seguidos, la cuenta queda bloqueada por 15 minutos.
- El aviso de error no dice si falló el correo o la contraseña, para no dar pistas a terceros.
- "Recordarme" mantiene la sesión solo en el equipo donde lo marcaste.

Documento de Especificación de Requerimiento

Aplicación de ejemplo — Inicio de sesión con correo y contraseña

Campo	Valor
Solicitud	#00000 (ejemplo)
Título original	"Necesito que los usuarios entren con correo y contraseña"
Producto / Módulo	Aplicación de ejemplo — Módulo de Autenticación
Fecha	2026-01-01
Estado	Especificación para revisión (pendiente de aprobación)

1 — Descripción del requerimiento (nivel usuario)

1.1 Contexto

Hoy la aplicación no exige identificarse: cualquiera con el enlace llega a las pantallas internas. Se necesita una autenticación básica para que solo usuarios válidos accedan y cada acción quede asociada a una persona.

1.2 Qué se necesita

Una pantalla de inicio de sesión con correo y contraseña que valide las credenciales, abra la sesión del usuario y proteja contra intentos masivos de adivinar la contraseña.

1.3 Escenarios cubiertos

- **Acceso válido:** el usuario ingresa credenciales correctas y entra a su panel.
- **Acceso inválido:** el usuario ingresa credenciales incorrectas y recibe un aviso genérico.
- **Bloqueo por fuerza bruta:** tras varios intentos fallidos seguidos, la cuenta se bloquea temporalmente.

1.4 Cómo lo verá el usuario

1. Al abrir la aplicación sin sesión, se muestra /login.
2. El usuario escribe correo y contraseña, opcionalmente marca "Recordarme".

3. Al hacer clic en "Iniciar sesión", si es válido entra a /dashboard.
4. Si es inválido, permanece en /login con un mensaje de error genérico.

1.5 Decisiones adoptadas

Decisión	Detalle
Identificador	El usuario inicia sesión con su correo electrónico, no con un nombre de usuario.
Mensaje de error	Genérico ("Correo o contraseña incorrectos"); no revela cuál de los dos falló.
Bloqueo de cuenta	5 intentos fallidos seguidos → bloqueo de 15 minutos.
Recordarme	Si se marca, la sesión persiste 30 días; si no, expira al cerrar el navegador.
Almacenamiento	Las contraseñas se guardan con hash (bcrypt/argon2), nunca en texto plano.

1.6 Fuera de alcance

- Recuperación de contraseña ("olvidé mi contraseña").
- Inicio de sesión con terceros (Google, etc.) y doble factor (2FA).
- Registro de nuevos usuarios desde esta pantalla.

2 — Especificación técnica

2.1 Clasificación del cambio

Atributo	Valor
Tipo	Nuevo feature (UI + endpoint de autenticación)
Impacta flujo / comportamiento	Sí (agrega control de acceso previo a las pantallas internas)
Impacta datos / esquema / procesos	Sí (campos de hash y contador de intentos en usuarios)
Tamaño estimado	Mediano

2.2 Requerimientos funcionales

ID	Requerimiento
RF-01	La pantalla /login permite ingresar correo y contraseña e iniciar sesión.
RF-02	Con credenciales válidas se crea la sesión y se redirige a /dashboard.
RF-03	Con credenciales inválidas se muestra un mensaje genérico sin abrir sesión.
RF-04	Tras 5 intentos fallidos seguidos, la cuenta se bloquea por 15 minutos.
RF-05	La opción "Recordarme" extiende la duración de la sesión a 30 días.
RF-06	Las contraseñas se almacenan con hash; nunca se guardan ni se registran en texto plano.
RF-07	Acceder a una ruta interna sin sesión válida redirige a /login.

2.3 Casos de uso

CU-01 — Inicio de sesión exitoso

- **Actor:** Usuario registrado.
- **Precondición:** existe una cuenta activa con esas credenciales.
- **Flujo:** abre /login → ingresa correo y contraseña → clic en "Iniciar sesión".
- **Postcondición:** sesión creada y redirección a /dashboard.

CU-02 — Bloqueo por intentos fallidos

- **Actor:** Usuario (o atacante).
- **Precondición:** la cuenta no está bloqueada.
- **Flujo:** falla la contraseña 5 veces seguidas.
- **Postcondición:** la cuenta queda bloqueada 15 minutos; los nuevos intentos se rechazan aunque la contraseña sea correcta.

2.4 Criterios de aceptación (BDD / Gherkin)

Característica: Inicio de sesión con correo y contraseña Escenario: Inicio de sesión exitoso (RF-01, RF-02) Dado que existe un usuario activo con correo "ana@ejemplo.cl" y contraseña válida Cuando ingreso ese correo y esa contraseña y hago clic en "Iniciar sesión" Entonces se crea mi sesión Y soy redirigido a "/dashboard" Escenario: Credenciales incorrectas (RF-03) Dado que ingreso un correo o una contraseña

incorrectos Cuando hago clic en "Iniciar sesión" Entonces permanezco en "/login" Y veo el mensaje "Correo o contraseña incorrectos" Y no se crea ninguna sesión Escenario: Bloqueo tras intentos fallidos (RF-04) Dado que fallé la contraseña 5 veces seguidas para "ana@ejemplo.cl" Cuando intento iniciar sesión por sexta vez con la contraseña correcta Entonces el acceso es rechazado por cuenta bloqueada Y el bloqueo se mantiene durante 15 minutos Escenario: Recordarme extiende la sesión (RF-05) Dado que inicio sesión correctamente Y marqué la opción "Recordarme" Cuando se crea mi sesión Entonces la sesión permanece válida durante 30 días Escenario: Las contraseñas no se guardan en texto plano (RF-06, seguridad) Dado que se registra la contraseña de un usuario Cuando se consulta el almacenamiento Entonces el valor guardado es un hash y no la contraseña en texto plano Escenario: Ruta protegida sin sesión (RF-07, regresión) Dado que no tengo una sesión iniciada Cuando intento abrir "/dashboard" Entonces soy redirigido a "/login"

2.5 Modelo de datos / cambios técnicos

En la entidad de usuarios se agregan: password_hash, failed_attempts (contador) y locked_until (timestamp de fin de bloqueo). Nuevo endpoint POST /auth/login que valida credenciales, gestiona el contador de intentos y emite la cookie/token de sesión. Middleware de autenticación que protege las rutas internas. Sin nuevas dependencias más allá de la librería de hashing.

2.6 Consideraciones

- **Regresión:** las pantallas internas siguen funcionando igual una vez autenticado; solo se antepone el control de acceso.
- **Seguridad:** hashing con sal (bcrypt/argon2), mensaje de error genérico para no enumerar usuarios, bloqueo por fuerza bruta, cookies de sesión HttpOnly + Secure, y nunca registrar la contraseña en logs (OWASP A07: fallas de identificación y autenticación).
- **Migración:** los usuarios existentes sin password_hash deben pasar por un proceso de definición de contraseña antes de poder iniciar sesión.